# Penetration Testing Report

## HTB – Archetype

## Executive Report

---

### Target

Windows Host

### Assesment Type

Penetration Testing Laboratory

### Prepared by

José Martín

### Assessment Period

August – September 2026

### CONFIDENTIALITY

Educational & Professional Portfolio

# Index

1. Statement of Confidentiality....2
2. Engagement Contacts....2
3. Executive Summary....2
4. Approach....3
5. Assignment....3
6. Scope....3
7. Assessment summary....4
8. Detailed Walkthrough....4
    8.1 Reconaissance....4
    8.2 Enumeration....4
        8.2.1 SMB Enumeration....5
        8.2.2 Microsoft SQL Server Enumeration....5
    8.3 Initial Exploitation....5
    8.4 Post Exploitation....6
        8.4.1 Windows Enumeration....6
        8.4.2 Automated Privileged Escalation Enumeration....6
        8.4.3 WinPeas Enumeration....7
        8.4.4 Administrator Credentials Discovery....7
        8.4.5 Administrator Access via WinRM....7
9.Remediation Summary....8
10. Appendix A : Finding Severities....9
11. Appendix B : Tools....9
12. Appendix C : Technical report....10

# 1. Statement of Confidentiality

This report was produced as a part of a personal penetration testing laboratoy exercise.

The information contained in this document is intended solely for educational and professional portfolio purpose. Any Ip Address, credential , flag and system information referenced herein belong to the target laboratory enviroment and must not be used against unauthorized systems.

Distribution of this report should be limited to educational, recruitment and professional development  purpose.

# 2. Engagement Contacts

| Assessor Contact | | | |
|---|---|---|---|
| **Assessor name** | **Title** | **Project** | **Assessor email** |
| X | Project Director | Archetype | X@htbcompany.htb |
| José Martín | Penetration Tester | Archetype | Jose@htbcompany.htb |

# 3. Executive Summary

A penetration test was conducted against the Archetype virtual machine from Hack The Box to identify vulnerabilities that could allow unauthorized access and privilege escalation.

The assessment identify several vulnerabilities affecting both SMB service and Microsoft SQL Server including SMB service misconfiguration, exposed credentials in a configuration file and elevated privileges for a common user.

The vulnerabilities could be chained to achieve full compromise of the target . Initial access was obtained due to misconfiguration on the SMB services which allows access to share that contained a file with the Microsoft SQL Server credentials. These was used to access to the MSSQL Service, The compromised SQL Server account was a member of the sysadmin server role , so the xp_cmdshell functionality of the Microsoft SQL Server could be used to enumerate the target system and find a file that contained the admin`s credentials. Subsequently this credentials were used on the winRM service to access it and enumerate it.

The assessment demostrate the weakness in the authentication control process and local privilege management could be chainned together to achieve the full compromise of the target system.

# 4. Approach

The assessment followed the standard penetration testing methodology

1. Reconnaissance
2. Service Enumeration
3. Initial Exploitation
4. Post Exploitation
5. Privilege Escalation
6. Collection Evidences

# 5. Assignment

| Assignment | | | |
|---|---|---|---|
| **From** | **To** | **Start** | **End** |
| Project Director | José Martín | 22/08/2026 | 02/09/2026 |

| Target | | |
|---|---|---|
| Name | Platform | Operating System |
| Archetype | Hack the Box | Windows |

The objectives are

- Obtain initial access to the target system
- Escalate privileges to admin
- Retrieve the available flags
- Document the attack path and identified vulnerabilities
- Provide remediation recomendations

# 6. Scope

In scope

- Windows operating system
- Network services
- Local privilege escalation vectors

# 7. Assessment summary

| Assesment summary | |
|---|---|
| **Findings** | **Severity** |
| SMB Service Misconfiguration | Low |
| Exposed Credentials in Configuration file | Medium |
| Excesive MSSQL privileges / xp_cmdshell Enabled | High |
| OS Command execution via MSSQL | Critical |
| Sensitive credentials exposed in Powershell history | High |
| Administrative access via WinRM with compromised credentials | High |

# 8. Detailed Walkthrough

The process had the following phases

## 8.1 Reconaissance

Network reconaissance identified the following TCP services

- SMB
- MSSQL
- WinRM

The presence of the SMB, Microsoft SQL Server and WinRM suggested the further enumeration of these services to identify available resources , configurations , authentication mechanism and posible vector attacks.

SMB enumeration identified the backups share as readable. Although Nmap reported anonymous read access, manual testing with a NULL session was denied. Access to the share was subsequently confirmed using the Guest account with an empty password

## 8.2 Enumeration

The enumeration process had the following phases

### 8.2.1 SMB Enumeration

The SMB Share enumeration identified a  non- administrative share named “backups” which was accessible with READ persmissions. Although Nmap tool reported Anonymous Read Access, direct Null authentication was denied when manually tested with smbclient. Access to the share was succesfully confirmed using the Guest account with a empty password.

The prod.dtsconfig configuration file was then discovered and downloaded from the share using the guest account. The file contained  a Sql Server Connection String with credentials for the ARCHETYPE\sql_svc user account stored in clear text.

The exposure of these credentiasl represent a security weakness beacuse an account with limited SMB access can retrieve credentials intended for a database access. The exposed credentials were validated against the Microsoft SQL Server service to determine their effective privileges and the resulting impact.

### 8.2.2 Microsoft SQL Server Enumeration

The exposed credentials were successfully validated against the Microsoft SQL Server service. The enumeration of the database management system confirmed that the user account had the role admin and the databases contained in the database managment system were four system databases, all of them configured with multi-user access. No user-created databases were identified in the instance. Besided the Catalog Database referenced for the prod.dtsconfig file existed in the current Microsoft Sql Server instance.

## 8.3 Initial Exploitation

The xp_cmdshell functionality was initially disabled. Since the compromised account belonged to the SysAdmin server role, the Sql Server configuration was modified to enable the xp_cmdshell functionality. A whoami command was subsequently excuted through this functionality confirmind the user account was ARCHETYPE\Sql_Svc.

Successful command execution through this functionality provided a direct execution path from the Microsoft Sql Server service to the underlying Windows system.

## 8.4 Post Exploitation

The post exploitation process had the following phases

### 8.4.1 Windows Enumeration

The initial Windows enumeration was performed after obtaining operating-system command execution through the xp_cmdshell functionality. The ARCHETYPE\Sql_Svc account was identified as the security context to execute the commands. With the C:\Windows\System32 as the current working directory.

The C:\ Users directory was enumerated and the Administrator, Public and Sql_svc profiles were identifed. Rather than assuming that the Administrator directory could be accessed, the groups and privileges associated to the compromised sql_svc user security context were enumerated.

The account was not identified as a member of the local administrator group. However, SeImpersonate was found enabled in its security token. This privilege represents a potential privilege escalation vector, because it may allow the process to impersonate the security context of a authenticated client. Therefore, further enumeration and investigation were required to determine whether the privilege could be leverage to obtain a more privileged Windows context.

### 8.4.2 Automated Privileged Escalation Enumeration

Automated privileged escalation enumeration was prepared after manually identifying SeImpersonate privilege as a potential privilege escalation vector.

The WinPeasx64 executable was selected and transferred from the attacker`s machine to the target`s machine through HTTP and verified on the target. The executable was available on the

- C:\Users \Public\winPeasx64.exe

The next step was to execute WinPeas and analyze its output for additional privilege escalation vectors and to determine whether the manually identified SeImpersonate privilege finding was confirmed or whether another privilege escalation vector was available.

### 8.4.3 WinPeas Enumeration

The WinPeas enumeration did not immediately reveal a straightfoward local privilege escalation. The most interesting findings at this stage were

- NetNTLMv2 material
- Backups Share
- Services exposed by the host

Further investigation should therefore focus on determing whether the recovered credentials can be reused or cracked and whether the backups share contained additional sensitive information.

### 8.4.4 Administrator Credentials Discovery

The administrator credentials were obtained through manual local file enumeration, rather than directly through automated privileged escalation enumeration.

This demonstrated a common credential exposured scenario. Credentials included in a Powershell command were persisted in the user´s command history file and subsequently became accessible to an attcker operating under the same user context.

The expusore of valid admin credentials can allows an attacker to authenticate as a highly privileged local  user account and potentially obtain full control of the Windows host.

### 8.4.5 Administrator Access via WinRM

The previously discovered Administrator credentials were successfuly used againts the WinRM service identified during the initial reconaissance phase.

The successful evil-winrm connection was verified using the whoami command which confirmed that the session was running as:

ARCHETYPE\Administrator

With the administrative access established, post exploitation enumeration of the local users profiles was performed. The Sql_Svc desktop contained the user.txt file , while the administrator desktop contained the root.txt file. Both files were sueccesfully accessed from their respective user profiles.

# 9.Remediation Summary

The vulnerabilities found which are recommended to be fixed are:

**1. SMB service misconfiguration**

Restrict SMB access to only the necessary host, review Share permissions and remove unnecessary access such as “ Guest”

**2. Exposed credentials in a configuration file**

Remove hardcoded credentials from the configuration files. Use a secret-manager and immediatly rotate any  exposed credentials.

**3. Excessive MSSQL privileges / xp_cmdshell enabled**

Disabled the xp_cmdshell functionality when it is not necessary and apply the Least privilege principle to the MSSQL  accounts.

**4. OS Command execution via MSSQL**

Prevent application / service accounts from executing operating – system commands through MSSQL. Disable xp_cmdshell functionality and restrict privileges.

**5. Sensitive credentials exposed in a PowerShell history fi**le

Do not enter directly credentials into commands which could be logged. Remove or clear exposed credentials , rotate them and implement secure secret management mechanism

**6. Administrative access via WinRM with compromised credentials**

Restric WinRM service to unauthorized hosts, apply the principle of least privileges, use secure authentication and immediatly rotate the exposed credentials.

# 10. Appendix A : Finding Severities

Each finding has beeb assigned a severity rating of critical, high, medium , low. The rating is based on an assessment of the  priority which each finding should be viewed and the potential each one has on the confidenciality, integrity and availability of the Archetype`s data.

| Severity Definitions | |
|---|---|
| **Rating** | **Severity rating definition** |
| Critical | Allows full compromise of the system or unauthorized access to highly sensitive information. May result in remote code execution, administrative access, or complete control of the target. |
| High | Allows significant access to sensitive data or functionality, privilege escalation, or lateral movement. May require an additional condition or vulnerability to achieve full compromise. |
| Medium | May facilitate subsequent attacks or expose information useful to an attacker. Typically requires chaining with other vulnerabilities to achieve full compromise. |
| Low | Has limited impact or is primarily informational. Does not typically provide direct system access but may assist reconnaissance or enumeration. |

# 11. Appendix B : Tools

The tools used for this asigment were:

- Nmap
- Rpcclient
- Smbclient
- Impacket
- xp_cmdshell
- evil-winrm

# 12. Appendix C : Technical report

Detailed technical evidences, commands , exploitation steps, supportive  screenshots are available in the acompaying technical report:

See the attached file

Archetype_Technical_Report.pdf